

Checking for default user accounts

Most VPN solutions have the end-user-level authentication Xauth (Phase 1.5 of IKE) or Extended Authentication enabled by default. So with the *psk-crack* output alone, it will not be possible to get into the internal network. After the initial peer authentication, Xauth is required before the VPN gateway grants access.

Xauth login credentials can be captured by using “fiked”, a command-line tool that impersonates the VPN gateway’s IKE responder and sniffs the authentication data by intercepting the IKE traffic. You need to redirect IKE traffic to *fiked* for sniffing, which can be done with the help of ARP spoofing. Given below is a simple example of *fiked*. The *-g* switch specifies the IP address of the gateway, captured data is written to a file with the *-l* switch, *-d* is used to run it in daemon mode, and *-k* is for “group id: shared key” representation:

```
root@bt:~# fiked -g 192.168.1.50 -k testgroup:secretkey -l output.txt -d
```

In some cases, the VPN gateway will have default user accounts, which the pen-tester can use for Xauth. If not, extensive social engineering or information gathering will do the trick. You may use a proper IPsec VPN client like the Cisco EasyVPN client for the final verification.

Testing the VPN gateway for vendor specific vulnerabilities

There are hundreds of known IPsec/IKE vulnerabilities. Exploitation of these can cause disruption of VPN gateway services, so testing the gateway for these is very important. The following three websites are very useful; they list the known vulnerabilities of different VPN solutions:

1. National Vulnerability Database
http://web.nvd.nist.gov/view/vuln/search-results?query=ipsec&search_type=all&cves=on
2. Secunia <http://secunia.com/>
3. SecurityFocus <http://www.securityfocus.com/>

Sophisticated vulnerability assessment tools like Metasploit Framework Pro, Qualys, Core Impact, etc, can be used to test the VPN gateway against known vulnerabilities, along with custom-created exploit scripts. Security patches, OS upgradation or additional configuration may be needed to mitigate these threats, as guided by the vendor.

By compromising a VPN gateway server, the attacker can gain access to valuable internal resources, so organisations need to make sure that VPN gateways are hardened against these threats. Vulnerability assessment and penetration-testing of the VPN gateway, along with periodic reviews of configured security policies, can help organisations to tighten up overall security. 

By: Arun Thomas

The author is an information security specialist with 8 years of experience in information and network security domains. His qualifications include 30+ information and network security certifications like CISSP, and expertise in security tools, methods, technologies and best practices. He is the co-founder and CTO of Netsentries (www.netsentries.com), an information security consulting company. Direct your feedback and queries to arun@netsentries.com.

IPSR Bags Red Hat International Award for the 4th Consecutive Year



Get trained by faculty team headed by RHCA Certified Professionals



RHCA RHCDs RHCSS RHCVA RHCE

Modules Starting Every Week

Awards

- Winner of Red Hat International Award 2008, 2009, 2010 & 2011
- Winner of Red Hat GLS National Awards 2004, 05, 06, 07 & 08

Faculty & Infrastructure

- 15 member faculty crew led by RHCE, RHCA, RHCSS, RHCDs, RHCA certified professionals
- Global standard infrastructure offered at our International Centre located in Kochi

Achievements

- Produced 3000+ RHCEs, 42 RHCSSs & 3 RHCA

ipshr solutions ltd
redefining excellence

Kochi South • Kochi North • Kozhikode
Trivandrum • Kottayam

Tel : 0484 - 2344560, 0481 - 2561410 / 20

Mob: 09447294635, 09447169776

www.ipshr.org • training@ipshrsolutions.com

IPSR, The Best in Red Hat Certifications